

RansomShield — Aide-mémoire de soutenance

Discours complet — 8 min de présentation + 5 min de démo

Codjo Fréjus Loïc SANGRONIO — 24 juin 2026

À lire au calme avant la soutenance ; en séance, s'en servir comme filet de sécurité, pas comme texte à réciter mot à mot. Le numéro « Diapo N » correspond exactement au numéro affiché dans le panneau de diapositives. Les **flèches vertes** sont des phrases à prononcer pour enchaîner vers la diapo suivante.

Diapo 1/22 — OUVERTURE

Excellence Monsieur le Président du jury, Mesdames et Messieurs les membres du jury, bonjour.

Le sujet ayant fait l'objet de notre étude est intitulé : *Conception et mise en place d'un système de détection et de réponse aux attaques ransomware dans un environnement contrôlé*.

Nous vous présentons aujourd'hui RansomShield — un système conçu de bout en bout pour détecter et contrer les attaques ransomware, de manière contrôlée et traçable, avec une validation humaine à chaque étape décisive.

↪ **Voici comment s'articule cette présentation.**

Diapo 2/22 — SOMMAIRE

Notre présentation s'articule en cinq parties : contexte et problématique, revue de littérature, conception, réalisation et résultats, et conclusion. Nous terminerons par une démonstration en conditions réelles.

↪ **Commençons par le contexte et la problématique.**

Diapo 4/22 — CONTEXTE

Aujourd'hui, les entreprises, les hôpitaux, les universités fonctionnent grâce à leurs données numériques. Le ransomware — un logiciel malveillant qui rend les données inaccessibles puis exige une rançon — exploite précisément cette dépendance. En 2023, ces attaques ont progressé de 73 % selon l'ENISA, avec un coût moyen de plus d'un million de dollars par incident. Ce qui est grave : sans outil adapté, une attaque passe en moyenne 21 jours sans être détectée.

↪ **Ce constat nous amène à la problématique centrale.**

Diapo 5/22 — PROBLÉMATIQUE

Les antivirus fonctionnent par reconnaissance d'empreintes. Face à une variante inédite, ils restent aveugles : les données sont chiffrées, les sauvegardes effacées, les dommages deviennent irréversibles.

Il n'existe pas de solution libre et démontrable pour détecter ces attaques par leurs comportements, avec un contrôle humain à chaque étape. Trois défis ont structuré ce travail : les variantes inconnues, la diversité des systèmes, et le risque d'une réponse automatique non validée.

↪ **Ces défis ont défini les six objectifs que voici.**

Diapo 6/22 — OBJECTIFS

Pour répondre à cette problématique, six objectifs précis ont guidé ce travail.

D'abord, surveiller en temps réel les activités fichiers sur chaque terminal. Ensuite, analyser ces activités pour calculer un niveau de risque. Puis, déclencher automatiquement des alertes dès qu'un comportement suspect est détecté. Le principe fondateur : soumettre chaque action proposée à la décision d'un opérateur humain. L'accès est en outre sécurisé par une double authentification — mot de passe et code temporaire valide 30 secondes. Et pour valider l'ensemble, des scénarios d'attaque représentatifs ont été définis et exécutés.

↪ **Voyons maintenant les fondements théoriques de ce travail.**

Diapo 8/22 — DÉFINITION & COMPORTEMENTS

Un ransomware agit toujours selon le même schéma : il renomme vos fichiers avec une extension inhabituelle pour les rendre illisibles, dépose une note de rançon, puis efface les sauvegardes pour rendre toute récupération impossible. Il utilise parfois des outils légitimes pour passer inaperçu.

Ce sont ces comportements observables — ces traces — qui forment la base de notre approche. Surveiller ces actions en temps réel permet de réagir avant que les dommages soient irréversibles.

↪ **Mais pourquoi les outils existants ne suffisent-ils pas ?**

Diapo 9/22 — SOLUTIONS EXISTANTES

Face à cette menace bien documentée, des solutions existent. Voyons pourquoi elles restent insuffisantes pour notre contexte.

Les antivirus ne reconnaissent que les menaces déjà cataloguées dans leur base de données. Les SIEM — systèmes de centralisation des journaux d'activité — collectent des informations, mais sans chercher activement des comportements suspects. Les EDR — solutions de surveillance avancée des terminaux — sont très efficaces, mais leur coût les rend inaccessibles pour la grande majorité des organisations — PME, hôpitaux, administrations, associations — qui n'ont pas les budgets des grands groupes.

RansomShield occupe cet espace laissé vacant : une solution libre, comportementale, déployable sur n'importe quelle infrastructure, avec un contrôle humain intégré à chaque étape — conçue pour les entreprises et organisations qui veulent se protéger sans dépendre de solutions propriétaires coûteuses.

↪ **Voyons maintenant comment ce système a été conçu.**

Diapo 11/22 — ARCHITECTURE

Voici l'architecture générale — à lire de gauche à droite.

Un agent sur chaque terminal observe toute activité inhabituelle sur les fichiers. Ces observations sont transmises au serveur central, qui calcule un score de risque. Dès que ce score dépasse le seuil configuré, une alerte est générée et une action de protection est proposée à l'opérateur. C'est lui qui prend la décision finale. Le système n'agit jamais seul.

↪ **Voyons de plus près les quatre composants.**

Diapo 12/22 — LES 4 COMPOSANTS

Voyons maintenant de plus près les quatre composants qui constituent ce système.

L'agent de surveillance, d'abord : installé sur chaque machine, il observe en temps réel toute activité inhabituelle sur les fichiers et conserve ces informations localement, pour ne rien perdre même en cas de coupure réseau.

La console de supervision, ensuite : c'est le poste de commandement, là où l'opérateur suit les alertes, prend ses décisions et consulte l'historique complet de toutes les actions.

Le module de découverte réseau : il signale automatiquement les nouvelles machines, mais aucune n'est intégrée au système sans accord explicite de l'administrateur.

Enfin, le simulateur : il reproduit des scénarios d'attaque réalistes, sans déployer le moindre malware réel — ce qui a permis de valider le système en toute sécurité.

→ **Qui sont les acteurs qui interagissent avec ce système ?**

Diapo 13/22 — DIAGRAMME USE CASE

Deux profils d'utilisateurs interagissent avec le système. L'administrateur configure et pilote : il connecte les agents, définit les règles et lance les simulations. L'analyste SOC traite les incidents au quotidien : il consulte les alertes, approuve ou rejette les actions proposées, et suit l'historique des événements. L'analyste ne peut pas modifier la configuration — cette séparation garantit l'intégrité du système.

→ **Passons maintenant à la réalisation concrète.**

Diapo 15/22 — CHOIX TECHNIQUES

Les choix techniques ont été guidés par trois critères : portabilité multi-OS, facilité de déploiement, et démontrable sans infrastructure coûteuse.

Le serveur et la console sont développés avec Laravel. L'agent de surveillance est en Python, portable sur Windows, Linux et macOS. Les tests ont été conduits sur trois machines virtuelles en réseau isolé. L'accès à la console est protégé par double authentification : mot de passe puis code temporaire valide 30 secondes.

→ **Voyons concrètement comment l'agent et le moteur fonctionnent.**

Diapo 16/22 — AGENT & MOTEUR DE DÉTECTION

Entrons dans le cœur du système : l'agent de surveillance et le moteur de scoring.

Voici comment fonctionne l'agent au quotidien : dès son démarrage, il est reconnu par le serveur central grâce à un jeton sécurisé à usage unique. Il commence alors à surveiller les dossiers et envoie régulièrement un signal de vie au serveur, toutes les 30 secondes.

Pour illustrer le moteur de scoring : imaginons qu'un fichier soit renommé avec l'extension `.locked` — cette extension inhabituelle est un signal connu des ransomwares. Ce comportement ajoute 80 points au score de risque. Si en plus une note de rançon apparaît dans le même dossier, 55 points s'ajoutent. Le score atteint 135 — bien au-dessus du seuil critique de 100. En moins de cinq secondes, une alerte est générée et un incident de sécurité est ouvert dans la console. Le système attend ensuite la décision de l'opérateur.

→ **Côté analyste, voici ce que la console SOC offre.**

Diapo 17/22 — CONSOLE SOC

Venons-en maintenant à la console SOC — l'interface que l'opérateur utilise au quotidien pour surveiller, réagir et rendre des comptes.

La console regroupe vingt-trois pages en quatre sections : supervision, infrastructure, détection et réponse, et configuration.

Ce qui est fondamental : chaque action proposée passe obligatoirement par la file d'approbation. L'analyste l'approuve ou la rejette explicitement. Aucune action ne s'exécute en silence.

Dès qu'une alerte est levée, l'opérateur est notifié par quatre canaux simultanément : interface web, e-mail, signal sonore et webhook.

↪ **Qu'est-ce que les tests ont donné ?**

Diapo 18/22 — TESTS & RÉSULTATS

Cinq scénarios d'attaque ont été définis, du chiffrement simple à la chaîne complète en 22 événements, exécutés sur trois machines virtuelles en réseau isolé — sans jamais déployer de malware réel. Pour chaque scénario, trois indicateurs ont été mesurés : délai de détection, intégrité des données, et complétude de la chaîne jusqu'à la décision de l'opérateur.

Les résultats sont constants : cinq scénarios exécutés, cinq détectés en moins de cinq secondes, zéro événement perdu. Limite assumée : les tests ont été conduits sur Linux uniquement.

↪ **Place maintenant à la démonstration live.**

Diapo 19/22 — DÉMONSTRATION LIVE — checklist 5 min, hors chrono

Suivre le guide de démonstration.

1. Console SOC ouverte : 3 agents en ligne
2. SSH sur `rs-client-1` : renommage `.locked` + note de rançon
3. Revenir sur la console : alerte critique apparue en moins de 5 secondes
4. **File d'approbation** : approuver l'action, montrer le rollback
5. **Timeline** : tout est horodaté
6. Simulation kill chain complète : 22 événements

↪ **Revenir à la présentation pour conclure.**

Diapo 21/22 — CONCLUSION & PERSPECTIVES

RansomShield couvre l'intégralité du cycle de traitement d'un incident : détection sur le terminal, analyse comportementale, alerte, décision de l'opérateur, archivage complet. Il est opérationnel, démontrable, construit sans malware réel. Les limites sont assumées : Linux uniquement, HTTP en environnement contrôlé.

Les perspectives sont tracées : sécuriser les communications pour la production, affiner les rôles, et doter le moteur d'un apprentissage automatique pour reconnaître les anomalies avec plus de précision. Chaque remarque du jury est pour nous une opportunité de progresser.

↪ **Nous restons à votre disposition pour vos questions.**

Diapo 22/22 — MERCI & QUESTIONS DU JURY — aide-mémoire

Dans un monde où les systèmes automatisent nos décisions, RansomShield rappelle une conviction simple : la machine peut détecter, mais c'est l'humain qui décide. Ce n'est pas une contrainte technique — c'est un choix éthique.

Merci pour votre aimable attention et pour le temps accordé à ce travail.

- **Python vs C/Go ?** → Watchdog exploite inotify nativement — CPU minimal, portable Linux/Windows/macOS
- **Fausses alertes ?** → Seuils configurables ; l'**opérateur humain** valide ou rejette avant toute action
- **Pourquoi pas HTTPS ?** → LAN contrôlé ; chiffrement TLS = 1^{re} perspective pour la production
- **Différence avec un antivirus ?** → L'antivirus reconnaît les empreintes ; RansomShield observe le comportement
- **Linux uniquement : faille ?** → **Non** — ce n'est pas une faille de sécurité, c'est une limite de **périmètre de validation**. L'agent Python + Watchdog est nativement portable (Linux, Windows, macOS) par conception. Seuls les tests ont été conduits sur Linux, par contrainte de temps et de ressources — ce qui est standard pour un projet de ce niveau. L'extension Windows reste la 1^{re} priorité d'évolution.

*Reformuler la question avant de répondre. Garder les **captures d'écran** prêtes.*